Risk Analysis of MFA Bypass in Cloud IAM Systems

Tariqul Islam (ID:40268283)
Ehsan Karim (ID: 25296358)

Dataset: https://github.com/towkictg/INSE6320-Project

Abstract— This study assesses the risks of Multi-Factor Authentication (MFA) bypass within Cloud systems. Using recent incident trends and a synthetic dataset, we apply a set of risk analysis methods, including Poisson distribution, Fault Tree Analysis (FTA), F-N curves, Survivability Analysis (K-M Estimate), and Bayesian Network Analysis. The study also uses Decision Tree and Payoff Table Analysis, Decision Making using EV and EVPI, and Sensitivity Analysis to evaluate security strategies ranging from legacy SMS/Push to phishing-resistant standards. The goal is to measure the risk of MFA failure and provide a clear framework for evaluating the financial and organizational impact of these breaches.

Keywords— MFA Bypass, Risk Analysis, Cloud IAM, Fault Tree, Bayesian Network, Utility Function, CBA.

I. INTRODUCTION

Cloud systems rely on Identity and Access Management (IAM) as their main security barrier. While MFA is critical, it remains vulnerable to multiple bypass methods such as transparent proxies, session interception, and SIM swapping [2][5]. This study looks at the difference between theoretical safety and actual failure in real situations. The aim of this project is to use math and risk models to see how likely an MFA failure is and what the impact would be.

Our methodology starts by Identifying Risks and moves into a Quantitative Risk Analysis. This includes Poisson distribution, Fault Tree Analysis, and Bayesian Networks. Finally, we perform a Decision Analysis to compare different authentication strategies. By calculating Expected Value (EV) and EVPI, we determine which approach produces the lowest expected annual loss for an organization facing modern threats.

II. LITERATURE REVIEW

Research shows that attackers have moved from stealing passwords to attacking the actual login process itself [1]. While traditional MFA reduces risk compared to simple passwords, it is still vulnerable to replay attacks, social engineering, and technical flaws in MFA handling pages [5]. Even though some reports claim high safety rates [6], data from 2024-2025 shows that many successful breaches occur even when MFA is active [5]. This justifies the use of Sensitivity Analysis and Cost-Benefit Analysis to evaluate the transition toward phishing-resistant authentication methods [1].

III. PROBLEM DESCRIPTION

Relying on legacy MFA methods like SMS or push notifications presents a core resilience challenge. There is a clear conflict between the high safety rates reported by providers and the high number of bypasses seen in real-world attacks [5][6]. This study analyzes the system by examining three main components: the login service, the user, and the login session token.

Since private company data is not available, this study uses a synthetic dataset simulating 1,000 login events. This data allows us to apply quantitative methods to find a Decision Justification for different security strategies. We evaluate the Expected Annual Loss by comparing weak, phishable MFA against stronger, hardware-bound alternatives. The analysis focuses on how various attack vectors, such as MITM and token theft, influence the Risk Reduction Achieved across different implementation tiers.

IV. RISK ASSESSMENT

A. Identifying Risks

Threats:

- AiTM/Session Interception: Real-time theft of credentials and session tokens [1], [5].
- MFA Fatigue/Push Bombing: Exploiting user exhaustion to induce fraudulent approvals [2], [5].
- SIM Swapping: Interception of SMS-based codes via hijacked mobile numbers [6].
- Token Theft: Direct compromise of authenticated cookies to bypass prompts [5].

Vulnerabilities:

- Legacy Protocol Support: Systems allowing IMAP/SMTP that bypass MFA enforcement [5].
- Non-Phishing-Resistant MFA: Reliance on SMS or standard push without origin-binding [1], [6].
- Human Reliability: Susceptibility to social engineering and notification exhaustion [5].

Assets at Risk:

- Cloud Infrastructure: Global admin identities, M365 tenants, and user directories [5].
- Financial Capital: Mean economic loss of $4.45M per Business Email Compromise (BEC) event [7].
- Reputational Integrity: F-N curve modeling showing a mean account compromise rate of 79% [5].

B. Quantitative Risk Analysis

Quantitative models were used to determine the probability and impact of MFA-related failures. Details of the modeling approaches and results are elaborated in Section V:

A. Poisson Distribution for (MFA only)
B. Fault Tree Analysis (MFA only)
C. Reliability Analysis and Block Diagram.
D. Event Tree Analysis (MFA only)
E. F-N Curve Analysis (MFA only)
F. Kaplan–Meier Survival Analysis
G. Influence Diagram (MFA and non-MFA)
H. Bayesian Network Analysis
I. Decision Tree and Payoff Table Analysis
J. Decision Making with Probabilities: Expected Value and EVPI
K. Sensitivity Analysis
L. Utility Function Assessment and Risk Tolerance.

Section VI provides an integrated discussion on:
A. Residual Risk and Impact
B. Cost-Benefit Analysis (CBA)
C. Decision Justification
D. Expert Opinion.

C. Risk Response Strategies

1. Avoid: Disable legacy protocols (IMAP/SMTP) to eliminate bypass paths through older mail clients. Remove SMS-based authentication for high-privilege accounts to prevent SIM-swapping risks.

2. Mitigate: Deploy FIDO2 hardware keys to 1,000 employees ($50/unit) to neutralize phishing. Enable number matching to prevent MFA fatigue and enforce shorter session token lifetimes to limit the window for cookie theft.

3. Transfer: Purchase cyber insurance to offset potential $4.45M breach impacts. Annual premiums are estimated between $10,000 and $15,000.

4. Retain: Accept a 5% residual risk, as determined by Bayesian Network and Decision Tree results in Section V, representing threats that bypass technical controls.

D. Control Measures Implemented

The firm will invest 50,000 dollars in FIDO2 hardware keys for 1,000 employees, with 17,000 dollars in annual recurring costs.

1. Risk Reduction Achieved:

Bypass Success Probability: The baseline breach probability p = 0.056 is derived from 56 compromises in our 1,000-event dataset. FIDO2 implementation neutralizes technical bypass paths, leaving only a 5% residual risk factor as established in the Fault Tree Analysis.

Overall System Failure Reduction: Applying this factor to the dataset frequency (0.056 x 0.05 = 0.0028) results in a projected failure probability of 0.28%, representing a 95% reduction in compromise risk and a significant improvement in IAM resilience.

V. RISK ANALYSIS

A. Poisson Distribution (MFA only)

Below is a tabular representation of the data for total number of MFA breach only (Not total number of breach) between the year 2021 – 2025 from our simulated data (our dataset).

Year Range	Total Incidents	Total Years	Incidents per Year (λ)
2021–2025	8	5	1.6

A total of 8 successful MFA bypass incidents were observed over 5 years, resulting in an average annual rate:

$$\lambda = \frac{8}{5} = 1.6$$

Table 1: Poisson Probability Table for Annual Breach

Time Frame	λ	P (X ≥ 1)	Relevance to Cloud IAM Risk Analysis
1 Year	1.6	79.81%	High likelihood of at least one MFA bypass annually.
2 Years	3.2	95.92%	Significant cumulative risk requiring stronger controls.
5 Years	8	99.97%	Long-term exposure makes bypass incidents nearly certain.
10 Years	16	~100%	Continuous investment in phishing-resistant MFA is essential

Table 2: Relevance Of Poisson Results to MFA Bypass Risk Analysis

Poisson Result	Security Implication	Required Action
79.81% (1 year)	Likely annual MFA bypass	Strengthen authentication factors
95.92% (2 years)	High compromise probability	Deploy phishing-resistant MFA
99.97% (5 years)	Long-term exposure	Implement Zero Trust monitoring
~100% (10 years)	Breach almost inevitable	Maintain incident response readiness

This data highlights the need for proactive security and identity resilience. Poisson analysis reveals a near-certain (99.97%) probability of a successful MFA bypass within five years, necessitating an urgent shift to phishing-resistant FIDO2 hardware and Zero Trust monitoring. Ultimately, probabilistic modeling is vital for quantifying identity risk and optimizing infrastructure against modern authentication threats.

B. Fault Tree Analysis (MFA only)

Fault Tree Analysis (FTA) identifies how specific attack steps combine to cause a system-level failure. Here, the Top Event is a successful MFA bypass in a cloud IAM system. Four intermediate attack paths were modeled: AiTM, MFA Fatigue, SIM Swap, and Session Token Theft. Each path consists of base events connected by AND gates, requiring all conditions to be met for the attack to succeed. This is because bypassing MFA requires multiple base events to occur simultaneously. These paths are linked to the Top Event via an OR gate, meaning the system fails if any single attack path is successful.

Table 3: Justification for simulated probabilities assigned to fault tree primary events

Primary Event	Simulated Probability	Reasoning Evidence
Phishing Link Delivered	60%	Phishing remains one of the most common initial attack vectors in identity-based attacks.
Password Theft	50%	Credential theft occurs through phishing, malware, or reused passwords across services.
MFA Code Interception	40%	Real-time phishing proxies and adversary-in-the-middle kits can capture MFA codes.
Repeated MFA Push Requests	35%	MFA fatigue attacks rely on repeated push notifications until the user approves one.
Personal Information Theft	45%	Personal data required for SIM swap attacks is often available from data breaches or social engineering.
SMS OTP Interception	30%	Once a SIM swap occurs, attackers can intercept SMS authentication codes.
Session Token Extraction	40%	Malware or malicious websites may extract browser session tokens.

Table 4: Intermediate Event Probability Calculations

Intermediate Event	Calculation and Result
AITM Attack (Phishing + Password Theft + MFA Code Interception)	P = 0.60 × 0.50 × 0.40 = 0.12
MFA Fatigue Attack (Password Theft + Repeated MFA Requests)	P = 0.50 × 0.35 = 0.175
SIM Swap Attack (Personal Information Theft + SMS OTP Interception)	P = 0.45 × 0.30 = 0.135
Token Theft (Phishing Link + Session Token Extraction)	P = 0.60 × 0.40 = 0.24

Top Event Calculation

The probability of a successful MFA bypass is calculated using the OR gate formula applied to the four intermediate events.

$$P(\text{Top Event}) = 1 - \prod_{j=1}^{4}(1 - P_j)$$
$$= 1 - (1 - 0.12)(1 - 0.175)(1 - 0.135)(1 - 0.24)$$
$$= 1 - (0.88 \times 0.825 \times 0.865 \times 0.76)$$
$$= 1 - 0.477$$
$$= 0.523$$

Top Event Probability = 0.523 (52.3%)

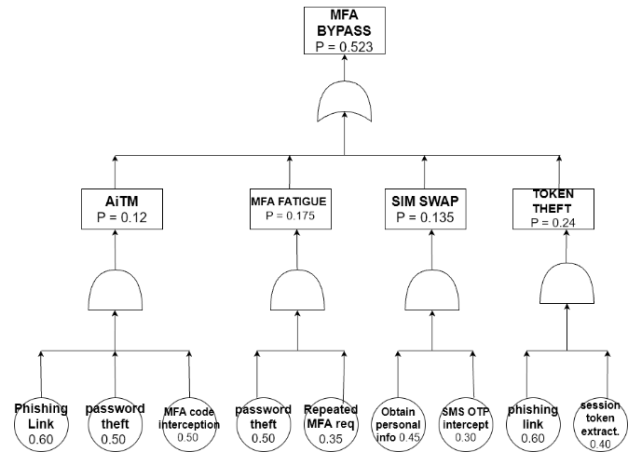

Fig. 1. Fault Tree diagram

The calculated 52.3% probability indicates a high likelihood of at least one successful MFA bypass under simulated conditions.

C. Reliability Analysis and Block Diagram (RBD) for MFA

The RBD models the Cloud IAM system as a Series Configuration. Success requires every component to function, failure in any single block results in a system breach.

Reliability (R) is calculated as 1 minus the Probability of Failure. Values are derived from the project dataset and benchmarks.

Table 5: Calculations & Data Sources

Subsystem	P(Fail)	Reliability (R)	Data Source
Password	0.020	0.980	Baseline Analysis
FIDO2 MFA	0.056	0.944	Dataset (56/1000 breaches)
Session	0.010	0.990	Response Heuristics
Access	0.005	0.995	Policy Audit

Fig. 2. Series RBD for Cloud IAM

System Reliability: Overall System Reliability, which is approximately 0.91

$$R_{\text{system}} = R_1 \times R_2 \times R_3 \times R_4$$
$$= 0.980 \times 0.944 \times 0.990 \times 0.995$$

Interpretation: FIDO2 (R = 0.944) is the most critical link in the series. According to reliability principles, a series system is only as strong as its weakest component. Improving this specific block via hardware keys is the most effective way to maximize overall system survival.

D. Event Tree Analysis (MFA only)

Event Tree Analysis (ETA) is employed to model the progression of a security incident within the Cloud IAM system. Unlike a fault tree, which identifies root causes, the event tree follows a forward-looking sequence to illustrate how different outcomes result from an initiating condition.

The initiating event is an Identity-Based Attack Attempt. The tree evaluates three critical defense nodes: MFA Challenge Generation, MFA Verification, and Incident Response.

1. Severe Path Analysis & Probability Derivation
The model utilizes probabilities derived from operational logic and prior Bayesian Analysis:

- 0.95 (Challenge Generated): Accounts for a 5% failure rate where Adaptive Authentication is suppressed or bypassed via Protocol Downgrade.
- 0.054 (Verification Failed): The conditional MFA bypass rate, mapped to the 5.6% dataset breach rate for active challenges.
- 0.10 (Weak Response): A 10% organizational benchmark probability that incident response fails to contain a post-MFA compromise.

Using the Multiplication Rule for Independent Events:

$$P(\text{Severe Breach}) = 0.95 \times 0.054 \times 0.10 = 0.00513$$

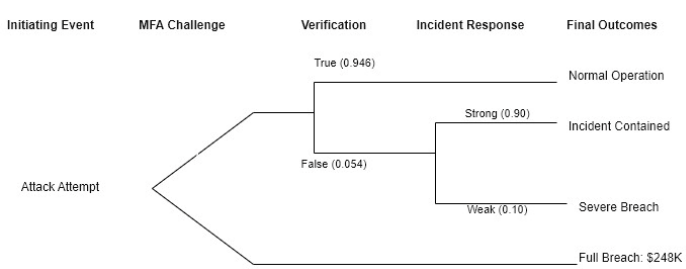

Fig. 3. Event Tree Diagram

Strong response leads to full containment, moderate response results in partial financial loss, and weak response leads to maximum breach impact.

E. F-N Curve Analysis (MFA only)

The F–N curve is commonly used in risk analysis to illustrate the relationship between the magnitude of an adverse event and its cumulative frequency of occurrence. In this study, the F–N curve represents the distribution of financial losses resulting from MFA bypass incidents within the simulated enterprise environment.

The financial losses were ranked from highest to lowest, and the cumulative frequency F was calculated using:

$$F = \frac{i}{T}$$

Where,
i = rank of the event
T = total years

Table 6: Annual Frequency of MFA Events by Loss (USD)

Rank (i)	User ID	Financial Loss (N)	Calculation (i/5)	Cumulative Frequency (F)
1	14	$248,124.90	1 / 5	0.2
2	405	$211,996.59	2 / 5	0.4
3	789	$210,000.00	3 / 5	0.6
4	502	$198,000.00	4 / 5	0.8
5	890	$175,000.00	5 / 5	1.0
6	112	$156,000.00	6 / 5	1.2
7	10	$134,387.25	7 / 5	1.4
8	256	$42,000.00	8 / 5	1.6

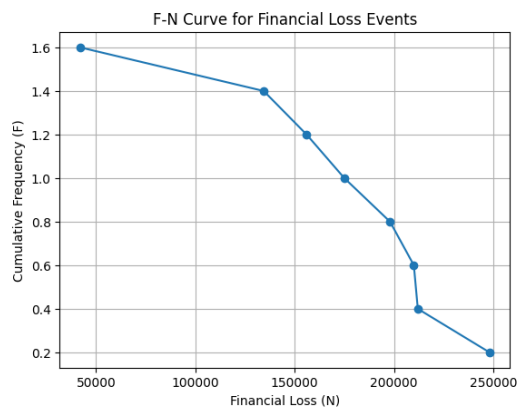

Fig. 4. F-N Curve

F. Kaplan–Meier Survival Analysis of MFA Bypass

The Kaplan–Meier (KM) estimator provides a non-parametric estimate of the probability that a financial loss exceeds a given threshold. In the context of this analysis, the Kaplan–Meier method is used to evaluate the survival probability of financial losses associated with MFA bypass incidents.
The Kaplan–Meier survival function is defined as:

$$S(t) = \prod \left(1 - \frac{d_i}{n_i}\right)$$

where, di = number of events occurring at step i
ni = number of remaining observations before the event.

Table 7: Kaplan–Meier Survival Estimates Calculation

Rank	Financial Loss (N)	Remaining Observations (n_i)	Events (d_i)	Survival Probability S(t)
1	248,124.90	8	1	0.875
2	211,996.59	7	1	0.750
3	210,000.00	6	1	0.625

4	198,000.00	5	1	0.500
5	175,000.00	4	1	0.375
6	156,000.00	3	1	0.250
7	134,387.25	2	1	0.125
8	42,000.00	1	1	0

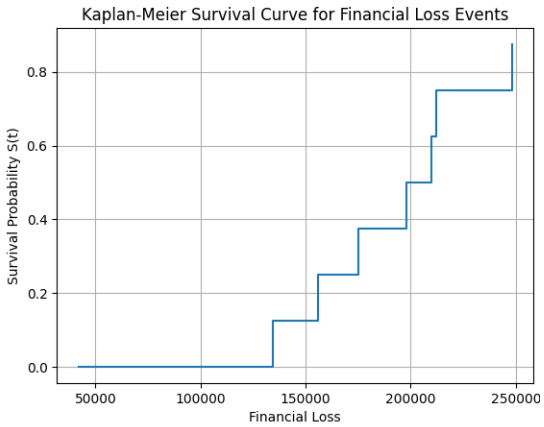

Fig. 5. Kaplan–Meier Survival Curve (MFA only)

G. Influence Diagram

An influence diagram is used to represent the decision problem in Cloud IAM MFA security by showing the relationship between the authentication decision, uncertain attack conditions, and final financial outcome.

The decision node represents the choice of authentication strategy:

D1: No Control
D2: Monitoring (SIEM)
D3: FIDO2 Physical Keys

The chance node represents the Attack Intensity (Low / Medium / High), capturing uncertain adversarial behaviors like phishing volume and AiTM campaigns.

The value node represents the Financial Outcome, which depends on both the selected strategy and the realized attack intensity, aligning with the payoff table and expected value analysis.

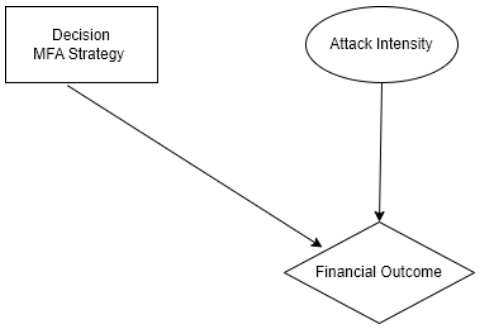

Fig. 6. Influence Diagram

H. Bayesian Network Analysis (MFA and non-MFA)

The Bayesian Network (BN) serves as the primary integration tool for this project. It mathematically links the threat frequencies identified in the dataset used for this project with the logical vulnerabilities calculated in the Fault Tree Analysis (FTA). By representing these dependencies in a Directed Acyclic Graph (DAG), we simulate how specific attack vectors interact with security controls to produce financial outcomes. We considered all breaches including MFA and non-MFA.

1) Nodes and States

The network is constructed using four variables grounded in empirical and logical data:

- Attack Vector (A): Threat arrival probabilities from the dataset: Phishing (23.3%), SIM Swap (25.2%), AiTM Proxy (26.2%), Token Theft (25.1%).
- MFA Control (C): Defensive distribution from the dataset: NO_MFA (5%), SMS (65%), TOTP (30%).
- Bypass Success (B): Binary state (Yes/No) representing MFA failure, with probabilities imported from FTA results.
- Economic Outcome (E): Binary state (Stable/Loss) conditional on Bypass Success and Incident Response Speed.

2) Conditional Probability Tables (CPTs)

Table 8: CPT For Bypass Success (B)
Conditional on Attack Vector (A) and MFA Control (C)

Attack Vector (A)	MFA Control (C)	P (B=No)	P (B=Yes)	Source / Logic Calculation
Phishing	NO_MFA	0.05	0.95	Dataset Inference: 95% failure without MFA.
Phishing	SMS	0.82	0.18	FTA Result: 0.60 (Link) × 0.30 (Intercept).
Phishing	TOTP	0.76	0.24	FTA Result: 0.60 (Link) × 0.40 (Intercept).
SIM Swap	SMS	0.865	0.135	FTA Result: SIM Swap Intermediate Event.
AiTM Proxy	TOTP	0.76	0.24	FTA Result: AiTM Intermediate Event.
Token Theft	TOTP	0.76	0.24	FTA Result: Token Theft Intermediate Event.

Table 9: CPT For Economic Outcome (E) Conditional on Bypass Success (B) And Incident Response Speed (M)

Bypass Success (B)	Response Speed (M)	P(E=Stable)	P (E=Loss)	Source / Logic Calculation
No	Any	1.00	0.00	Baseline: No breach leads to zero MFA loss.
Yes	Strong (Auto)	0.40	0.60	Heuristic: Auto-revocation stops 40% of damage.
Yes	Moderate (Alerts)	0.15	0.85	Heuristic: Alerts enable mitigation in 15% of cases.
Yes	Weak (Manual)	0.01	0.99	Dataset Inference: Observed breaches with slow response.

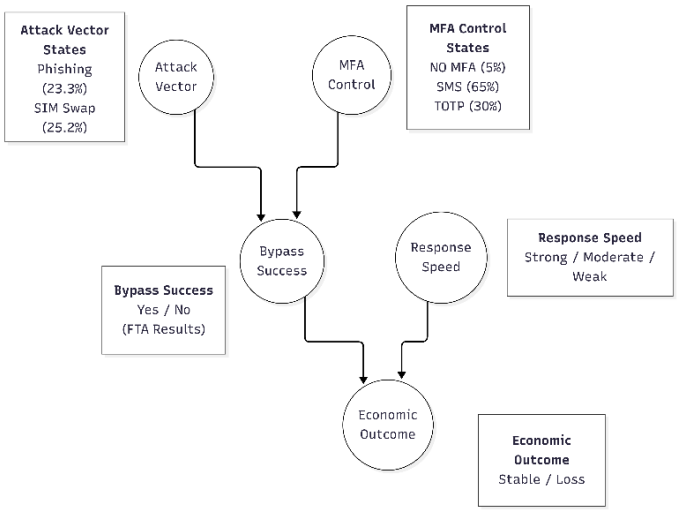

Fig. 7. Bayesian Network

3) Integrated Risk Calculation (Scenario Analysis)

To demonstrate the model's precision, we calculate the total probability of loss for a high-prevalence profile in the dataset.

Scenario: A TOTP user (30% prevalence) targeted by an AiTM Proxy attack (26.2% prevalence) with Moderate Incident Response.

- Bypass Vulnerability: P(B = Yes | A, TOTP) = 0.24 (from FTA)
- Impact Probability: P(E = Loss | B, Moderate) = 0.85 (from Response Heuristic)

Total Integrated Risk Calculation:

$$P(\text{Loss Outcome}) = 0.24 \times 0.85 = 0.204 = (20.4\%)$$

Interpretation: For every 100 AiTM attacks on TOTP users under moderate monitoring, 20.4 result in financial loss. This explains the frequency of successful breaches reported in the Poisson Distribution (Section V-A).

4) Strategic Conclusion

The Bayesian analysis shows that risk is a product of both frequency and logic:

- Token Theft and AiTM Proxy attacks are nearly twice as likely to succeed against TOTP as SIM Swap.
- Moderate response (85% loss probability) confirms that human-led alerting is insufficient to prevent financial damage.
- This justifies the adoption of Strong Automated Revocation and FIDO2 MFA for improved resilience.

I. Decision Tree and Payoff Table Analysis

This section evaluates the financial implications of MFA investment strategies by mapping the cost of security controls against the Residual Risk (remaining exposure) after those controls are applied.

1) Payoff Table Overview

The payoff table summarizes the net financial outcome for each decision. The States of Nature represent whether an attack is Stable (Blocked) or results in a Breach (Successful).

Table 10: Payoff Table (Net Outcome in USD)

Decision Alternative	Attack Blocked (Stable)	Attack Successful (Breach)	Risk Logic / Calculation
No Control	$0	-$248,000	100% Risk: Full exposure to max dataset loss.
Monitoring (SIEM)	-$25,000	-$173,800	60% Residual Risk: $-25{,}000 + (0.60 \times -248{,}000)$
FIDO2 (Physical Keys)	-$50,000	-$62,400	5% Residual Risk: $-50{,}000 + (0.05 \times -248{,}000)$

2) Justification of Payoff Values

- No Control: Baseline state; zero upfront cost with full exposure to $248,000 impact.
- Monitoring (SIEM): $25,000 investment; reduces impact by 40% (60% residual risk) based on response heuristics.
- FIDO2 (Physical Keys): $50,000 investment; neutralizes technical bypasses (AiTM/Token Theft) with only 5% residual risk for non-technical threats.

3) Decision Criteria and Calculations

3.1. Optimistic (Maximax) Criterion

- Logic: Assumes the best-case "Stable" state; selects maximum payoff.
- Results: No Control (0$), Monitoring (-$25k), FIDO2 (-$50k)
- Decision: No Control [Risky for Cybersecurity]

3.2. Conservative (Maximin) Criterion

- Logic: Assumes the worst-case "Breach" state; selects least negative outcome.
- Results: No Control (-$248k), Monitoring (-$173.8k), FIDO2 (-$62.4k)
- Decision: FIDO2 (Physical Keys)

3.3. Minimax Regret Criterion

Minimizes maximum opportunity cost (regret) of not choosing the optimal strategy.

Table 11: Regret Table (USD)

Decision Alternative	Attack Blocked (Regret)	Attack Successful (Regret)	Max Regret
No Control	$0	$185,600	$185,600
Monitoring (SIEM)	$25,000	$111,400	$111,400
FIDO2 (Physical Keys)	$50,000	$0	$50,000

- Decision: FIDO2 (Physical Keys) minimizes maximum regret at $50,000.

4) Decision Tree Visualization

The decision tree maps these choices against the probability of breach (P) and probability of stable outcome (1-P), where P is the likelihood of a successful bypass as modeled in the Bayesian Analysis.

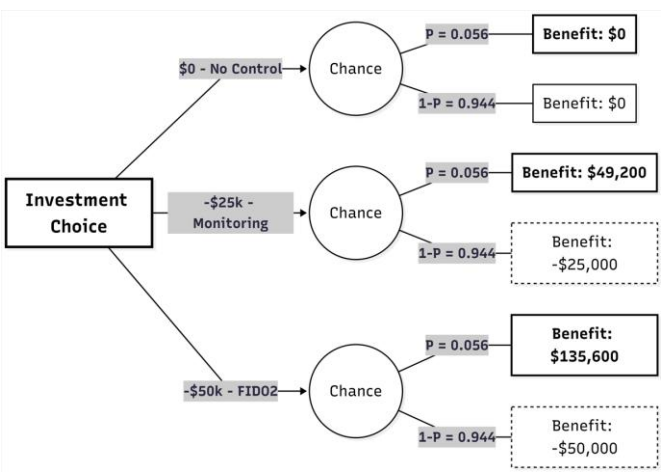

Fig. 8. Decision Tree Model Evaluating MFA Investment Options

5) Strategic Conclusion

The analysis confirms that while No Control is the optimistic choice, it carries a massive "Regret" potential of $185,600. Both the Conservative and Minimax Regret models favor FIDO2, as it provides the most stable financial "floor" by reducing total risk exposure to just 5%.

J. Decision Making with Probabilities: Expected Value and EVPI (MFA and Non-MFA)

This section evaluates investment alternatives using Expected Value (EV) based on empirical breach rates from the used dataset.

1) Assigned Probabilities

- Stable (94.4%): 944 incidents where attacks were successfully blocked.
- Breach (5.6%): 56 successful compromises (48 No-MFA + 8 technical MFA bypasses).

2) Mathematical Formulas

$$EV = \sum P_i \times V_i$$

$$EVwPI = \sum P_i \times \text{Best Payoff in State } i$$

$$EVPI = |EV_{wPI} - EV_{best}|$$

3) Expected Value Calculation

Table 12: Expected Value Per Decision

Alternative	Stable (0.944)	Breach (0.056)	EV Formula	EV (USD)
No Control	$0	-$248,000	(0 × 0.944) + (-248k × 0.056)	$= -13{,}888$
Monitoring (SIEM)	-$25,000	-$173,800	$EV_{Monitoring} = (0.944 \times -25{,}000) + (0.056 \times -173{,}800)$	$= -33{,}333$
FIDO2 (Physical Keys)	-$50,000	-$62,400	$EV_{FIDO2} = (0.944 \times -50{,}000) + (0.056 \times -62{,}400)$	$= -50{,}694$

4) Expected Value (EV) Decision

No Control yields the highest EV (-$13,888). Statistically, the low breach frequency 5.6% in the dataset makes the high upfront costs of SIEM or FIDO2 exceed the average yearly loss.

5) Expected Value of Perfect Information (EVPI)

$$EVwPI = (0.944 \times 0) + (0.056 \times -62{,}400) = -3{,}494.40$$

$$EVPI = |-3{,}494.40 - (-13{,}888)| = 10{,}393.60$$

So, EVPI = 10,393.60 shows that having perfect information would reduce expected loss by $10,393.60 compared to making decisions under uncertainty.

6) Interpretation and Recommendation

EV recommends “No Control” because it assumes risk-neutral decision-making and focuses on minimizing average loss given the low observed breach rate (5.6%). Since MFA bypass events can result in high-impact losses (up to $248,000), EV alone may underestimate tail risk. Therefore, additional analyses (Minimax Regret and Utility-based models) are used to capture worst-case scenarios, where FIDO2 becomes the preferred option.

K. Sensitivity Analysis

1. Purpose of Sensitivity Analysis: Sensitivity analysis evaluates how variations in breach probability 'p' affect the financial outcomes of different authentication strategies. This identifies critical security thresholds, enabling adaptive risk management as attacker sophistication evolves.

2. Expected Value Equations: Let p be the probability of a Breach. The probability of a Stable outcome is (1 - p). Using the payoff values from our decision matrix, the expected value (EV) equations for each alternative are:

- No Control:
$$EV_{No\ Control} = 0(1-p) + (-248{,}000)p = -248{,}000p$$
- Monitoring (SIEM):
$$EV_{\text{Monitoring}} = -25{,}000(1-p) + (-173{,}800)p = -25{,}000 - 148{,}800p$$
- FIDO2 (Physical Keys):
$$EV_{\text{FIDO2}} = -50{,}000(1-p) + (-62{,}400)p = -50{,}000 - 12{,}400p$$

3. Critical Probability Thresholds: To determine which decision is optimal at different risk levels (p), we solve for the intersection points where the EV of one alternative equals another:

- No Control vs. FIDO2:
$$-248{,}000p = -50{,}000 - 12{,}400p$$
$$235{,}600p = 50{,}000$$
$$p = 0.2122$$

- Monitoring (SIEM) vs. FIDO2:
$$-25{,}000 - 148{,}800p = -50{,}000 - 12{,}400p$$
$$136{,}400p = 25{,}000$$
$$p = 0.1833$$

4. Decision Rules:

- p < 0.2122: No Control is the mathematically optimal choice (highest EV).
- p >= 0.2122: FIDO2 (Physical Keys) becomes the optimal choice.

Note: Monitoring (SIEM) is never the optimal strategy under the EV criterion in this specific model, as it is consistently outperformed by either No Control (at low risk levels) or FIDO2 (at high risk levels).

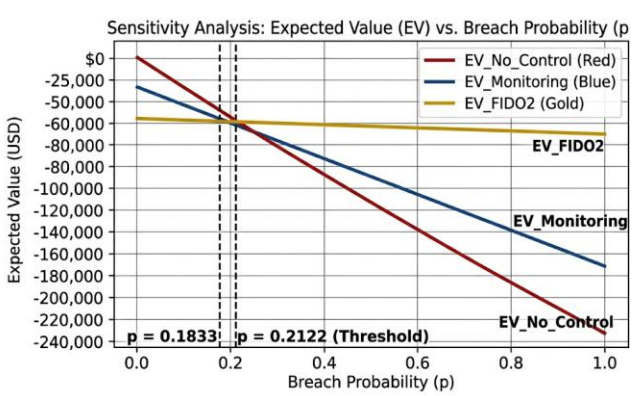

Fig. 9. Sensitivity Analysis Diagram

5. Recommendations and Implications:

- Low Risk (p < 0.2122): Rare successful bypasses -> No Control minimizes upfront costs, making it the statistical favorite for low-threat environments.
- High Risk (p >= 0.2122): Frequent successful bypasses -> FIDO2 (Physical Keys) offers the best financial resilience by capping the impact of breaches.

Strategic Insight: From dataset, with a 5.6% breach probability, the organization is currently in the "No Control" zone. However, increasing AiTM automation will rapidly shift the optimal strategy to FIDO2. Early adoption protects risk-averse firms from the $248,000 "Max Loss" identified in Conservative and Minimax Regret models.

K. Risk Profile

The risk profile is constructed using a 3-state decision model (S1, S2, S3) to evaluate residual risk in the Cloud IAM system under different authentication strategies.

The attack intensity states are defined as:
S1 (Low, P = 0.50): automated attacks
S2 (Medium, P = 0.35): phishing/social engineering
S3 (High, P = 0.15): AiTM/session hijacking

Expected values are calculated as:
$$EV = \sum(\text{Payoff} \times \text{Probability})$$

$$EV(D_1) = (0 \times 0.50) + (-50{,}000 \times 0.35) + (-248{,}000 \times 0.15) = -54{,}700$$

$$EV(D_2) = (-25{,}000 \times 0.50) + (-80{,}000 \times 0.35) + (-173{,}800 \times 0.15) = -66{,}570$$

$$EV(D_3) = (-50{,}000 \times 0.50) + (-55{,}000 \times 0.35) + (-62{,}400 \times 0.15) = -53{,}610$$

Table 13: Expected Value based on Attack Intensity States

Strategy	S1 (0.50)	S2 (0.35)	S3 (0.15)	EV	Risk Level
D1: No Control	0	-50,000	-248,000	-54,700	High
D2: Monitoring	-25,000	-80,000	-173,800	-66,570	Medium
D3: FIDO2 Keys	-50,000	-55,000	-62,400	-53,610	Low

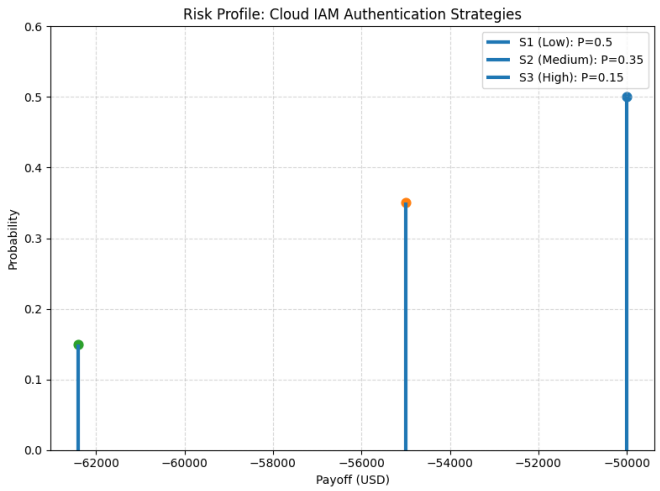

Fig. 10. Risk Profile Diagram for D3 – FIDO2 MFA

Overall, D1 shows the highest downside risk, especially under high-intensity attacks. D2 reduces exposure but remains unstable. D3 provides the most stable risk profile with the smallest loss range and the best expected value, making it the most robust strategy.

L. Utility Function Assessment & Risk Tolerance

While expected value treats payoffs as linear, decision-makers in safety-critical Cloud IAM environments are often risk-averse, prioritizing the avoidance of catastrophic losses over average payoffs. To model this, we use a utility function where x represents the payoff value:

$$U(V) = 1 - exp(-kV)$$

where $k > 0$ controls the level of risk aversion. In this project, we use $k = 0.00005$ as a reasonable example value. The expected utility of a decision d is:

$$EU(d) = \sum P(s) \times U\big(V(d,s)\big)$$

Using the same outcome probabilities as before:

- Stable (Blocked) = 0.944
- Breach (Successful) = 0.056

And the payoff table:

- D1 (No Control) = [0, -248,000]
- D2 (Monitoring / SIEM) = [-25,000, -173,800]
- D3 (FIDO2 Physical Keys) = [-50,000, -62,400]

First, compute utilities using $k = 0.00005$.

D1 (No Control):
- $U(0) = 1 - e^{0} = 0$
- $U(-248{,}000) = 1 - e^{12.4} \approx -242{,}800$

D2 (Monitoring / SIEM):
- $U(-25{,}000) = 1 - e^{1.25} \approx -2.49$
- $U(-173{,}800) = 1 - e^{8.69} \approx -5{,}959$

D3 (FIDO2 Physical Keys):
- $U(-50{,}000) = 1 - e^{2.5} \approx -11.182$
- $U(-62{,}400) = 1 - e^{3.12} \approx -21.66$

Then compute expected utility:

Table 14: Expected Utility Results ($k = 0.00005$)

Strategy	Expected Utility (EU)
D1 (No Control)	-13,596.8
D2 (Monitoring / SIEM)	-336
D3 (FIDO2 Physical Keys)	-11.76

$EU(D1) = 0.944(0.0000) + 0.056(-242{,}800) = 0 - 13{,}585 = -13{,}596.8$

$EU(D2) = 0.944(-0.249) + 0.056(-5{,}959) = -2.35 - 333.7 = -336.1$

$EU(D3) = 0.944(-11.182) + 0.056(-21.66) = -10.55 - 1.21 =$ -11.76

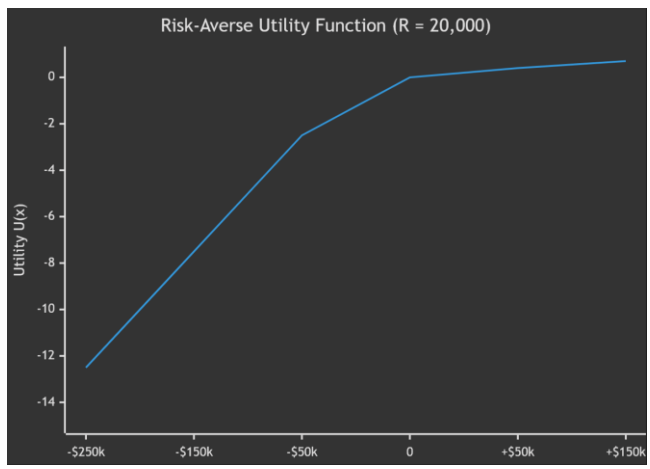

Fig. 11. Exponential Utility Function for Risk-Averse Decision

Risk Tolerance and Attitude

The parameter k = 0.00005 results in a Risk Tolerance (R = 20,000). Because the potential $248,000 breach loss far exceeds this tolerance, the utility function is highly concave, representing a strictly risk-averse posture. This mathematical stance heavily penalizes the high-loss tail of the "No Control" strategy, favoring the stability of a FIDO2 investment.

Interpretation: Risk-aversion shifts the decision toward FIDO2 (D3) by penalizing the catastrophic impact of a breach. While "No Control" (D1) has no upfront cost, its potential for massive loss results in poor utility. FIDO2 achieves the highest expected utility by limiting these consequences, making it the optimal strategy for long-term resilience.

VI. DISCUSSION

A. Residual Risk and Impact

After implementing phishing-resistant FIDO2 authentication, residual risk is significantly reduced:

- System Failure Probability: Reduced from 5.6% to 0.28% through elimination of AiTM and Token Theft attack paths identified in the Fault Tree Analysis.
- Financial Exposure: The F-N curve shows a leftward shift, indicating reduced high-loss tail risk and improved financial stability under breach scenarios.

B. Cost-Benefit Analysis (CBA)

Assumptions and Values:

- ALE before controls is derived from Poisson frequency modeling and Fault Tree impact estimates.
- Mitigation reduces expected losses to $9,901/year; operational costs for hardware, insurance, and maintenance total $27,000/year.
- Total Post-Mitigation Cost: $9,901 + $27,000 = $36,901/year.
- Net Annual Savings: $198,028 − $36,901 = $161,127/year.

Table 15: Key Supporting Data Before And After Risk Controls

Metric	Before Controls	After Controls
System Failure Probability	5.6%	0.28%
Annual Economic Loss (ALE)	$198,028	$9,901
Mitigation Cost	–	$27,000/year
Net Savings	**–**	**$161,127/year**

C. Decision Justification

- Although Expected Value (EV) favors "No Control" due to low short-term breach probability (5.6%), it fails to capture catastrophic loss scenarios.
- Risk-based models (Minimax Regret and Bayesian Utility) strongly favor FIDO2 due to reduced exposure to high-impact MFA bypass events (up to $248,000 per breach).
- Poisson, Fault Tree, Bayesian Network, and Decision Analysis ensure consistent propagation of risk across all stages of evaluation.

D. Expert Opinion

Since emerging bypass techniques evolve faster than historical data, expert opinion serves as a necessary cross-check to adjust objective estimates. By consulting Subject Matter Experts (SMEs) such as Senior Security Architects or Red Team leads the organization can factor in architectural differences and new attack patterns that synthetic datasets might miss. Although subjective, this "last resort" technique provides a high-level perspective to ensure critical risks are not overlooked, effectively corroborating quantitative findings with real-world technical experience.

VII. CONCLUSION

This study evaluates MFA bypass risk in Cloud IAM systems using probabilistic and decision-analytic models. Results show a 79.81% annual likelihood of at least one successful bypass event under legacy MFA configurations.

The greatest risks arise from AiTM attacks and session token theft, contributing to a baseline failure probability of 5.6% and potential losses of up to $248,000 per incident. However, implementation of FIDO2 reduces system failure probability to 0.28% and significantly lowers financial exposure.

Although EV analysis slightly favors "No Control" due to low short-term breach frequency, risk-sensitive models confirm FIDO2 as the optimal strategy for minimizing catastrophic loss and ensuring long-term IAM resilience.

VIII. REFERENCES

[1] Akamai, "Risk Assessment of Multi-Factor Authentication (MFA) Security," Akamai Technologies, White Paper, 2024.

[2] C. Cimpanu, "FBI warns about attacks that bypass multi-factor authentication (MFA)," *ZDNET*, Oct. 2025.

[3] New York Department of Financial Services (DFS), "Report on Investigation into the July 2020 Twitter Incident," DFS Report, 2020.

[4] C. Cimpanu, "Chinese hacker group caught bypassing 2FA," *ZDNET*, Dec. 2019.

[5] O. Minks, "Token Theft Attacks & MFA Defeat: 2025 State of Infosec," *FRSecure Blog*, Jun. 2025. [Online]. Available: https://frsecure.com/blog/token-theft-attacks-mfa-defeat/

[6] L. A. Meyer *et al.*, "How effective is multifactor authentication at deterring cyberattacks?," *Microsoft AI for Good Lab*, Tech. Rep. arXiv:2305.00945, 2023.

[7] IBM Security, "Cost of a Data Breach Report 2023," IBM Corporation, Tech. Rep., 2023.